

NEXPAY Multi-Cloud Security Capstone *Phase 1 — Architecture & ZTA Design* AWS · Azure · NIST SP 800-207 · PCI DSS v4.0.1 · MITRE ATT&CK

18 Security Controls	7 ZTA Pillars	12 MITRE Techniques	7 PCI DSS Requirements
----------------------	---------------	---------------------	------------------------

Scope: Lab environment designed at enterprise-grade architecture. Services are implemented using AWS free tier and minimal-cost alternatives where production equivalents exceed lab budget. Production extensions are documented explicitly.

1. Company Context

Phase 1

Step 1 — Company Identity

1.1 Who Is NexPay?

NexPay is a B2B FinTech SaaS platform that provides payment processing, invoicing, and financial operations tooling for small and mid-size businesses. Customers authenticate via a web portal to manage transactions, upload financial documents, and access reporting dashboards.

NexPay handles sensitive cardholder data and PII, making it subject to PCI DSS v4.0.1 compliance requirements. The platform processes payments via third-party payment processors and stores financial records, KYC documents, and transaction histories — making it a high-value target for credential theft, data exfiltration, and API abuse.

1.2 Sensitive Asset Inventory

Asset	Description	Compliance Scope	Storage Location
Cardholder Data (PAN, CVV)	Payment card numbers and verification values	PCI DSS Req 3, 4	RDS Aurora (encrypted)
PII	Customer names, SSNs, addresses, email	GDPR, CCPA	DynamoDB + RDS
KYC Documents	Passports, bank statements, ID verification	PCI DSS, AML	S3 (KMS encrypted)
API Keys / Credentials	Third-party payment processor tokens	All frameworks	Secrets Manager
Transaction	Payment records,	PCI DSS Req 10	DynamoDB + RDS

Asset	Description	Compliance Scope	Storage Location
History	invoices, audit trail		
IAM Credentials	AWS access keys, role credentials	CIS AWS Benchmark	IAM (no long-lived keys)

1.3 Architecture Overview

NexPay runs as a 3-tier web application on AWS with Azure providing identity federation and cross-cloud SIEM capabilities.

Tier	Components	Subnet Type	Cloud
Web Tier	EC2 + ALB + CloudFront + WAF	Public	AWS
App Tier	Lambda + API Gateway + Cognito	Private	AWS
Data Tier	RDS Aurora + DynamoDB + S3 + KMS	Isolated	AWS
Identity Layer	Entra ID + Conditional Access (federated)	N/A	Azure
SIEM Layer	Microsoft Sentinel (cross-cloud)	N/A	Azure

2. Threat Model

Phase 1	Step 2 — Threat Model
---------	-----------------------

2.1 Adversary Profiles

Adversary 1 — Financially Motivated Cybercriminals

The most likely threat actor for a B2B FinTech SaaS. Motivated by cardholder data, PII, and credentials they can monetize directly. Use commodity tooling, credential stuffing, phishing, and API abuse. Opportunistic but persistent once inside.

Adversary 2 — Malicious Insider

A disgruntled employee or contractor with legitimate access who exfiltrates financial records, customer data, or API keys. Particularly relevant because NexPay employees access internal portals and hold IAM roles with real permissions.

Adversary 3 — Nation-State / APT

Less likely at lab scale but architecturally relevant. Targets financial infrastructure for long-term persistence, supply chain compromise, and intelligence gathering. Designing against APT forces implementation of the strongest available controls.

2.2 Attack Scenarios — MITRE ATT&CK Mapping

Each scenario maps to a red team simulation in Phase 6. Detection and control columns map directly to controls built in Phases 2–5.

#	Scenario	MITRE Technique	Tactic	Detection	Control
1	Credential stuffing against Cognito portal	T1110.004	Credential Access	CloudWatch metric filter, GuardDuty	WAF rate limiting, Cognito MFA
2	Compromised employee IAM credentials	T1078.004, T1098	Initial Access, Persistence	GuardDuty IAMUser/AnomalousBehavior	Permission boundaries, SCPs
3	CloudTrail disruption (defense evasion)	T1562.008	Defense Evasion	CloudWatch StopLogging alarm	Log file validation, S3 MFA delete
4	S3 data exfiltration via misconfigured bucket	T1530	Collection	Macie PII finding, GuardDuty S3	Block Public Access, VPC endpoints
5	API Gateway abuse (injection/BOLA)	T1190	Initial Access	WAF blocked requests spike	WAF managed rules, API Gateway policy
6	IAM privilege escalation	T1098.001	Privilege Escalation	CloudTrail AssumeRole anomaly	SCPs, permission boundaries, Analyzer
7	Lambda compromise / cryptomining	T1496	Impact	GuardDuty Cryptocurrency finding	Lambda URL restrictions, Inspector

2.3 Trust Boundaries

Five trust boundaries define where Zero Trust enforcement points must exist. Each boundary is a place where ‘never trust, always verify’ is applied explicitly.

Boundary	Location	Enforcement Mechanism
TB-1	Internet → Web Tier	WAF + CloudFront + ALB (HTTPS only)
TB-2	Web Tier → App Tier	Cognito JWT validation at API Gateway
TB-3	App Tier → Data Tier	VPC endpoints + Security Groups + IAM role policies
TB-4	Employee/Admin → Internal Portal	Entra ID + Conditional Access + Cognito federation
TB-5	AWS Control Plane	SCPs + IAM guardrails + CloudTrail logging

3. Zero Trust Architecture Design

Phase 1	Step 3 — ZTA Design (NIST SP 800-207)
---------	---------------------------------------

NIST SP 800-207 Core Principle: *Never trust, always verify — regardless of network location. Every access request must be authenticated, authorized, and continuously monitored before access to any resource is granted.*

3.1 ZTA Pillar Implementations

Pillar 1 — Identity

Every human and non-human identity must be verified before access is granted. No implicit trust based on network location.

Component	NexPay Implementation
Customer Identity	Amazon Cognito User Pool — MFA enforced on all accounts
Employee Identity	Azure Entra ID — federated into Cognito via OIDC
Machine Identity	IAM Roles with permission boundaries — no long-lived access keys
Conditional Access	Entra ID Conditional Access — MFA + device compliance required
Threat Signals	GuardDuty IAM findings + Entra ID risky

Component	NexPay Implementation
	sign-in detection

ZTA Enforcement Point: *API Gateway rejects any request without a valid Cognito JWT. No token = no access. Every request is authenticated at the application boundary.*

Pillar 2 — Device

Devices must meet security posture requirements before accessing NexPay resources.

Component	NexPay Implementation
EC2 Hardening	No SSH key pairs — SSM Session Manager only
Patch Management	AWS Systems Manager Patch Manager — automated patching
Vulnerability Scanning	Amazon Inspector on EC2 and Lambda functions
Employee Device	Entra ID device compliance via Conditional Access policy
No Standing Access	SSM sessions are time-limited and fully logged in CloudTrail

ZTA Enforcement Point: *No EC2 instance has a public IP or open SSH port. All shell access goes through SSM — creating an auditable trail for every session with no persistent access path.*

Pillar 3 — Network

The network is hostile by default. Micro-segmentation prevents lateral movement between tiers.

Component	NexPay Implementation
VPC Design	3-tier subnet isolation across 2 Availability Zones
Public Tier	ALB + CloudFront + WAF only — no direct EC2 exposure to internet
App Tier	Lambda in private subnets — no internet ingress path
Data Tier	RDS + DynamoDB in isolated subnets — app tier access only
East-West Control	Security Groups as micro-perimeters between every tier
Network Visibility	VPC Flow Logs → CloudWatch → anomaly

Component	NexPay Implementation
Private Connectivity	detection alerts VPC Endpoints for S3, DynamoDB, Secrets Manager

ZTA Enforcement Point: *A compromised web tier instance cannot directly reach the database. Traffic must pass through the app tier security group — blast radius is contained by design.*

Pillar 4 — Application

Applications enforce their own authorization. Access is granted per-session, not per-network membership.

Component	NexPay Implementation
API Protection	API Gateway with Cognito JWT authorizer on every endpoint
WAF Rules	AWS WAF — SQLi, XSS, rate limiting, geo-blocking managed rules
Auth at Every Layer	Lambda functions validate caller identity independently
Least Privilege	Each Lambda function has its own scoped IAM execution role
API Visibility	API Gateway access logs — CloudWatch — anomaly detection

ZTA Enforcement Point: *API Gateway validates the JWT on every single request before Lambda is invoked. An expired or tampered token is rejected at the edge — Lambda never sees unauthenticated requests.*

Pillar 5 — Data

Data is protected at rest and in transit regardless of where it lives. Sensitive data is discovered and classified continuously.

Component	NexPay Implementation
Encryption at Rest	KMS customer-managed keys (CMKs) for RDS, DynamoDB, S3
Encryption in Transit	ACM TLS certificates — HTTPS enforced end-to-end, HTTP blocked
Secrets Management	AWS Secrets Manager — no hardcoded credentials anywhere in codebase
Sensitive Data Discovery	Amazon Macie — PII and PAN detection

Component	NexPay Implementation
	across all S3 buckets
Data Retention	S3 Object Lock for compliance retention of financial records
Key Rotation	KMS automatic annual key rotation enabled on all CMKs

ZTA Enforcement Point: *Even if an adversary exfiltrates a DynamoDB table or S3 object, the data is encrypted with a CMK they do not control. Exfiltration without the key yields unusable ciphertext.*

Pillar 6 — Visibility & ** Analytics**

All activity is logged, correlated, and analyzed. Threats are detected in near real-time across both clouds.

Component	NexPay Implementation
API Audit Trail	CloudTrail — every AWS API call logged to S3 + CloudWatch
Threat Detection	GuardDuty — ML-based anomaly detection and threat intel correlation
Real-Time Alerting	EventBridge → SNS for HIGH and CRITICAL severity findings
Metric Filters	CloudWatch — root usage, StopLogging, failed auth events
Posture Management	Security Hub — aggregates GuardDuty, Inspector, Macie, Config
Cross-Cloud SIEM	Microsoft Sentinel — ingests CloudTrail + Entra ID SigninLogs
Network Telemetry	VPC Flow Logs — lateral movement and port scan detection
Automated Response	Lambda auto-remediation — automated key deactivation on compromised-user detection

ZTA Enforcement Point: *Detection is not optional and not manual. Every attack scenario from the threat model has an automated detection path. MTTD is measured and tracked per technique.*

Pillar 7 — Automation & ** Orchestration**

Security responses are automated. Human intervention is reserved for decisions, not execution.

Component	NexPay Implementation
Incident Response	Lambda function — auto-deactivates access keys on compromised IAM-user findings; role-session revocation human-gated
IaC Security	CloudFormation Guard + Checkov in CI/CD pipeline
Compliance Enforcement	AWS Config rules — continuous compliance monitoring and drift detection
Auto-Remediation	Lambda triggered by Config rule violations — restores compliant state
Drift Detection	Config detects and alerts on any infrastructure configuration drift

ZTA Enforcement Point: A GuardDuty finding for a compromised IAM user triggers automatic access-key deactivation; role-credential findings route to a human-gated session-revocation path by design. Containment latency is measured in the incident lab (AWS-8), not assumed.

3.2 ZTA Enforcement Flow

Every user request passes through multiple ZTA enforcement points before reaching data. The flow below shows which pillar is enforced at each layer.

Layer	Service	ZTA Pillar(s)	Trust Boundary
Edge	CloudFront + WAF	Network + Application	TB-1
Load Balancer	ALB — HTTPS only, HTTP blocked	Data (TLS)	TB-1
Web Tier	EC2 — SSM-managed, no SSH	Device	TB-1
Auth Gate	API Gateway + Cognito JWT	Identity + Application	TB-2
Compute	Lambda — private subnet, scoped role	Network + Identity	TB-3
Secrets	Secrets Manager — no hardcoded creds	Data + Identity	TB-3
Database	RDS / DynamoDB — KMS encrypted	Data	TB-3
Monitoring	CloudTrail + GuardDuty + VPC Flow Logs	Visibility	TB-5
Response	EventBridge —	Automation	TB-5

Layer	Service	ZTA Pillar(s)	Trust Boundary
	Lambda auto-remediation		
Identity (Azure)	Entra ID + Conditional Access	Identity + Device	TB-4
SIEM (Azure)	Microsoft Sentinel	Visibility	TB-4 + TB-5

4. Security Control Mapping

Phase 1	Step 4 — Triple-Framework Control Mapping
---------	---

Mapping Approach: Every NexPay security control maps simultaneously to: (1) ZTA Pillar — which Zero Trust principle it enforces, (2) MITRE ATT&CK — which technique it detects or prevents, (3) PCI DSS v4.0.1 — which compliance requirement it satisfies.

4.1 Identity & ** Access Controls**

Control 1 — Cognito MFA Enforcement

Field	Detail
What It Does	Requires MFA for all NexPay customer logins via Cognito User Pool
ZTA Pillar	Identity
MITRE Technique	T1110.004 — Credential Stuffing
MITRE Tactic	Credential Access
PCI DSS	Requirement 8.4 — MFA for all access into CDE
AWS Service	Amazon Cognito User Pool
Lab Phase	Phase 2

Why It Matters: Credential stuffing is the #1 attack vector against FinTech portals. MFA breaks the attack even when credentials are valid and have been previously compromised.

Control 2 — IAM Permission Boundaries

Field	Detail
What It Does	Caps maximum permissions for all developer and service IAM roles
ZTA Pillar	Identity
MITRE Technique	T1098.001 — Additional Cloud Credentials
MITRE Tactic	Privilege Escalation

Field	Detail
PCI DSS	Requirement 7.2 — Least privilege access controls
AWS Service	IAM Permission Boundaries
Lab Phase	Phase 3 (AWS-1)

Why It Matters: *Even if an adversary compromises a developer role, permission boundaries prevent escalation beyond the defined ceiling — regardless of what IAM policies might otherwise allow.*

Control 3 — Service Control Policies (SCPs)

Field	Detail
What It Does	Organization-wide guardrails — blocks root usage, enforces MFA, restricts regions
ZTA Pillar	Identity + Automation
MITRE Technique	T1078 — Valid Accounts
MITRE Tactic	Initial Access, Persistence
PCI DSS	Requirement 7.3 — Access control systems enforcement
AWS Service	AWS Organizations SCPs
Lab Phase	Phase 3 (AWS-1)

Why It Matters: *SCPs are the ceiling above IAM. No policy within the account can override them — they are the last line of defense against misconfigured permissions across the entire organization.*

Control 4 — Entra ID Conditional Access

Field	Detail
What It Does	Enforces MFA + device compliance for employee access to NexPay internal portal
ZTA Pillar	Identity + Device
MITRE Technique	T1078.004 — Cloud Accounts
MITRE Tactic	Initial Access
PCI DSS	Requirement 8.4 — MFA for non-console administrative access
Azure Service	Entra ID Conditional Access Policies
Lab Phase	Phase 4

Why It Matters: *Employees are the insider threat vector. Conditional Access ensures that even a valid password is not sufficient — device posture and MFA are always required.*

Control 5 — IAM Access Analyzer

Field	Detail
What It Does	Continuously analyzes IAM policies for overly permissive or externally accessible resources
ZTA Pillar	Identity + Visibility
MITRE Technique	T1538 — Cloud Service Discovery
MITRE Tactic	Discovery
PCI DSS	Requirement 7.2 — Least privilege access
AWS Service	IAM Access Analyzer
Lab Phase	Phase 3 (AWS-1)

Why It Matters: *Catches cross-account access and unintended public resource exposure before an adversary does. Catches the gaps that manual IAM reviews miss.*

4.2 Network & ** Infrastructure Controls**

Control 6 — VPC 3-Tier Subnet Isolation

Field	Detail
What It Does	Separates web, app, and data tiers into distinct subnets with no direct cross-tier access
ZTA Pillar	Network
MITRE Technique	T1021 — Remote Services (lateral movement)
MITRE Tactic	Lateral Movement
PCI DSS	Requirement 1.3 — Network access controls and segmentation
AWS Service	VPC, Subnets, Security Groups, NACLs
Lab Phase	Phase 2

Why It Matters: *Micro-segmentation contains blast radius. A compromised web server cannot reach the database directly — it must traverse the app tier security group, triggering detection along the way.*

Control 7 — AWS WAF

Field	Detail
What It Does	Blocks SQLi, XSS, rate-limit violations, and

Field	Detail
ZTA Pillar	known malicious IPs at the application edge Network + Application
MITRE Technique	T1190 — Exploit Public-Facing Application
MITRE Tactic	Initial Access
PCI DSS	Requirement 6.4.2 — WAF on all internet-facing applications (mandatory)
AWS Service	AWS WAF with managed rule groups + API Gateway
Lab Phase	Phase 2

Why It Matters: *PCI DSS 6.4.2 explicitly mandates a WAF on all internet-facing applications. This is a direct compliance requirement, not just a best practice — failing this is an audit finding.*

Control 8 — VPC Flow Logs

Field	Detail
What It Does	Captures all network traffic metadata across every VPC subnet for analysis
ZTA Pillar	Network + Visibility
MITRE Technique	T1046 — Network Service Discovery
MITRE Tactic	Discovery
PCI DSS	Requirement 10.2 — Implement audit logs for all system components
AWS Service	VPC Flow Logs → CloudWatch Logs
Lab Phase	Phase 5 (Gap Fill)

Why It Matters: *Flow logs are what GuardDuty consumes internally. They also catch port scanning and unusual lateral movement between subnets that application-level logs will never see.*

Control 9 — VPC Endpoints

Field	Detail
What It Does	Routes traffic to S3, DynamoDB, and Secrets Manager through the AWS private backbone
ZTA Pillar	Network + Data
MITRE Technique	T1530 — Data from Cloud Storage
MITRE Tactic	Collection
PCI DSS	Requirement 4.2 — Protect cardholder data

Field	Detail
	transmitted over open networks
AWS Service	VPC Endpoints — Gateway (S3, DynamoDB) + Interface (Secrets Manager)
Lab Phase	Phase 2

Why It Matters: *Eliminates the risk of data exfiltration over the public internet. S3 and DynamoDB traffic stays inside the AWS network backbone — no internet gateway required for these services.*

4.3 Detection & ** Response Controls**

Control 10 — CloudTrail + CloudWatch Pipeline

Field	Detail
What It Does	Captures every AWS API call, creates metric filters for critical events, fires alarms
ZTA Pillar	Visibility & Analytics
MITRE Technique	T1562.008 — Disable Cloud Logs
MITRE Tactic	Defense Evasion
PCI DSS	Requirement 10.2 — Audit logs for all access to cardholder data
AWS Service	CloudTrail + CloudWatch Logs + SNS + EventBridge
Lab Phase	Phase 3 (AWS-2)

Why It Matters: *PCI DSS Requirement 10 mandates audit logs for every access to cardholder data. CloudTrail is the primary evidence source for compliance audits — and the first thing an attacker tries to disable.*

Control 11 — GuardDuty Threat Detection

Field	Detail
What It Does	ML-based threat detection across CloudTrail, VPC Flow Logs, and DNS query logs
ZTA Pillar	Visibility & Analytics
MITRE Technique	T1078.004 — Cloud Accounts, T1496 — Resource Hijacking
MITRE Tactic	Initial Access, Impact
PCI DSS	Requirement 10.7 — Detect and respond to failures of critical security controls
AWS Service	Amazon GuardDuty

Field	Detail
Lab Phase	Phase 3 (AWS-2)

Why It Matters: *GuardDuty correlates signals across three data sources simultaneously — something CloudWatch metric filters cannot do. It catches multi-step attacks that look benign in any single log source.*

Control 12 — Lambda Auto-Remediation

Field	Detail
What It Does	Automatically deactivates IAM access keys on GuardDuty compromised-user findings; alerts and tags role-credential findings for human-gated session revocation
ZTA Pillar	Automation & Orchestration
MITRE Technique	T1098.001 — Additional Cloud Credentials
MITRE Tactic	Persistence
PCI DSS	Requirement 12.10 — Implement an incident response plan
AWS Service	Lambda + EventBridge + IAM + SNS
Lab Phase	Phase 3 (AWS-3)

Why It Matters: *Automated response closes the MTTD-to-MTTR gap for IAM-user key compromise: keys are deactivated on detection, with containment latency measured in the lab. Role-credential compromise is deliberately human-gated — session revocation is destructive enough to warrant a decision, not a reflex.*

Control 13 — AWS Security Hub

Field	Detail
What It Does	Aggregates findings from GuardDuty, Inspector, Macie, and Config into a single pane
ZTA Pillar	Visibility & Analytics
MITRE Technique	Supports detection across all tactics
MITRE Tactic	All
PCI DSS	Requirement 6.3 — Identify and address security vulnerabilities
AWS Service	AWS Security Hub + CIS AWS Foundations Benchmark
Lab Phase	Phase 3 (AWS-2)

Why It Matters: *Security Hub is the compliance dashboard for PCI DSS auditors. CIS AWS Foundations Benchmark score gives a quantified posture metric that can be tracked and improved over time.*

Control 14 — Microsoft Sentinel (Cross-Cloud SIEM)

Field	Detail
What It Does	Ingests CloudTrail + Entra ID logs, runs unified KQL detection rules across both clouds
ZTA Pillar	Visibility & Analytics
MITRE Technique	T1078.004, T1098.003, T1562.008
MITRE Tactic	Initial Access, Privilege Escalation, Defense Evasion
PCI DSS	Requirement 10.4 — Review logs of all system components
Azure Service	Microsoft Sentinel + Log Analytics Workspace
Lab Phase	Phase 4

Why It Matters: *A single-cloud SIEM has blind spots. Sentinel correlating an Entra ID impossible travel event with a CloudTrail privilege escalation is a detection that neither cloud alone would surface.*

4.4 Data Protection Controls

Control 15 — KMS Customer-Managed Keys

Field	Detail
What It Does	Encrypts RDS, DynamoDB, S3, and Secrets Manager with CMKs NexPay controls exclusively
ZTA Pillar	Data
MITRE Technique	T1530 — Data from Cloud Storage
MITRE Tactic	Collection
PCI DSS	Requirement 3.5 — Protect stored cardholder data with strong cryptography
AWS Service	AWS KMS (CMKs with automatic annual rotation)
Lab Phase	Phase 2

Why It Matters: *PCI DSS Requirement 3 is non-negotiable for cardholder data. CMKs give NexPay exclusive control over encryption keys — AWS cannot decrypt the data without NexPay’s authorization.*

Control 16 — AWS Secrets Manager

Field	Detail
What It Does	Stores and rotates all credentials — DB passwords, API keys, third-party tokens
ZTA Pillar	Data + Identity
MITRE Technique	T1552.001 — Credentials in Files
MITRE Tactic	Credential Access
PCI DSS	Requirement 8.6 — Manage system and application accounts and credentials
AWS Service	AWS Secrets Manager + KMS
Lab Phase	Phase 5 (Gap Fill)

Why It Matters: *Hardcoded credentials in code or environment variables is the #1 Prowler and Wiz finding. Secrets Manager eliminates the entire credential exposure category by design.*

Control 17 — Amazon Macie

Field	Detail
What It Does	Continuously scans S3 buckets for PII, PAN data, and sensitive financial documents
ZTA Pillar	Data + Visibility
MITRE Technique	T1530 — Data from Cloud Storage
MITRE Tactic	Collection
PCI DSS	Requirement 3.2 — Identify all cardholder data and confirm scope
AWS Service	Amazon Macie
Lab Phase	Phase 5 (Gap Fill)

Why It Matters: *You cannot protect data you do not know exists. Macie continuously discovers and classifies sensitive data — satisfying PCI DSS Requirement 3.2 which mandates knowing where all cardholder data lives.*

Control 18 — ACM + HTTPS Enforcement

Field	Detail
What It Does	TLS certificates on all endpoints — HTTP requests redirected to HTTPS at the ALB

Field	Detail
ZTA Pillar	Data
MITRE Technique	T1557 — Adversary-in-the-Middle
MITRE Tactic	Collection
PCI DSS	Requirement 4.2.1 — Strong cryptography for cardholder data in transit
AWS Service	AWS Certificate Manager (ACM) + ALB HTTPS listener rules
Lab Phase	Phase 5 (Gap Fill)

Why It Matters: *PCI DSS Requirement 4 is explicit — cardholder data transmitted over open networks must be encrypted. No HTTP anywhere in the NexPay stack is a non-negotiable design requirement.*

5. Phase 1 Summary

18 Security Controls	7 ZTA Pillars	12 MITRE Techniques	7 PCI DSS Reqs
-----------------------------	----------------------	----------------------------	-----------------------

5.1 Coverage Summary

Framework	Coverage
ZTA Pillars (NIST SP 800-207)	All 7 pillars covered — Identity, Device, Network, Application, Data, Visibility, Automation
MITRE ATT&CK Techniques	T1078, T1098, T1110, T1190, T1496, T1530, T1538, T1552, T1557, T1562, T1021, T1046
PCI DSS v4.0.1 Requirements	Req 1 (Network), 3 (Data Storage), 4 (Data Transit), 6 (Vuln Mgmt), 7 (Access), 8 (Auth), 10 (Logging), 12 (IR)
AWS Services	Cognito, IAM, SCPs, WAF, CloudFront, ALB, Lambda, API Gateway, RDS, DynamoDB, S3, KMS, Secrets Manager, GuardDuty, CloudTrail, CloudWatch, EventBridge, Security Hub, Inspector, Macie, VPC Flow Logs, VPC Endpoints, ACM, Config
Azure Services	Entra ID Conditional Access, Microsoft Sentinel

5.2 Phase Completion Status

Step	Description	Status
Phase 1 — Step 1	Company Context (NexPay	COMPLETE

Step	Description	Status
Phase 1 — Step 2	B2B FinTech SaaS) Threat Model — 7 attack scenarios, 3 adversary profiles, 5 trust boundaries	COMPLETE
Phase 1 — Step 3	ZTA Architecture Design — all 7 NIST SP 800-207 pillars mapped to services	COMPLETE
Phase 1 — Step 4	Security Control Mapping — 18 controls triple-mapped to ZTA + MITRE + PCI DSS	COMPLETE
Phase 2	AWS 3-Tier Environment Build	NEXT

5.3 Lab vs Production Scope

The following table documents where lab constraints substitute for full production implementations. Portfolio transparency about lab scope is intentional — this demonstrates architectural awareness, not a gap.

Control	Lab Implementation	Production Extension
RDS Aurora	t3.micro single-AZ instance	Multi-AZ with read replicas
CloudHSM	KMS CMK (multi-tenant HSMs, FIPS 140-3 Level 3 validated)	CloudHSM (single-tenant, dedicated key custody, PCI PIN/HSM requirements)
WAF at Scale	Managed rules, basic rate limiting	Custom rules + bot management + Shield Advanced
Macie	Single scan per session	Continuous scheduled scanning with SNS alerting
Multi-Region	Single region (us-east-1)	Active-active multi-region with Route 53 failover
CI/CD Pipeline	GitHub Actions with Checkov	Full SDLC pipeline with security gates and approvals

Phase 1 Complete — Design & Planning Next: Phase 2 — AWS 3-Tier Environment Build